TRABAJO INTEGRADOR: ENUNCIADO Y RÚBRICA
CURSO: CIBERSEGURIDAD DE INTELIGENCIA ARTIFICIAL

I. DATOS GENERALES

PROGRAMA :	MAESTRÍA EN CIENCIA DE DATOS
PESO :	30% DE LA NOTA FINAL
EQUIPOS :	GRUPOS DE CUATRO INTEGRANTES
SE PRESENTA EN :	SESIÓN 3
HITOS CON RETROALIMENTACIÓN	SESIONES 4 Y 6
:	SESIÓN 8
SE SUSTENTA EN :	REPOSITORIO DE GITHUB Y GITHUB
ENTREGA :	PAGES

II. QUÉ SE PIDE

Cada grupo construye un **producto de inteligencia artificial generativa**, lo ataca y lo defiende, y deja todo en un repositorio de GitHub: el código, las pruebas, sus resultados y la documentación.

El centro del trabajo es el **modelo de amenazas** del producto. Un modelo de amenazas es el inventario ordenado de lo que puede salir mal en un sistema: contra qué, por dónde entra, qué rastro deja, qué tan grave es, qué lo reduce y qué queda abierto. Es la misma tabla que cada estudiante lleva sobre Financiera Andina desde la sesión 1. La diferencia es que aquí el grupo **mide** sobre su propio producto lo que la tabla afirma: si el ataque funciona, si el control lo detiene, cuánto deja pasar y qué rastro queda en el registro.

El trabajo evalúa el objetivo 6 del curso (crear el modelo de amenazas de un sistema completo, priorizando por explotabilidad e impacto) y usa todos los demás: analizar la superficie de ataque (1), explicar el mecanismo (2), medir (3) y evaluar la cobertura de un control (4).

III. EL PRODUCTO

El grupo elige qué construir. Puede ser ficticio o estar inspirado en su trabajo, con tres condiciones.

1. **Sin datos reales ni información confidencial.** Todos los datos son sintéticos. No se usan datos personales, nombres de clientes, arquitecturas internas reales ni nada que el empleador no haya publicado. Si el producto se inspira en un sistema real, se generaliza hasta que no sea reconocible. Rige el compromiso de uso del curso.
2. **Tres de cuatro componentes, y uno de ellos es el modelo de lenguaje que consulta documentos.**
3. **Un registro de eventos.** El producto guarda en archivo cada consulta, los documentos recuperados, las herramientas invocadas y la respuesta. Sin registro no se puede llenar con evidencia la columna «señal en el registro».

Componente	Ejemplo	Sesión
Obligatorio: un modelo de lenguaje que consulta documentos o datos (recuperación)	Asistente que responde sobre políticas internas	3 y 4
Un modelo de *machine learning* clásico que toma una decisión	*Scoring*, detección de fraude, clasificación de reclamos	2
Un agente que ejecuta acciones con herramientas	Abre tickets, envía correos, consulta un sistema	5
Memoria entre sesiones o varios agentes que se comunican	Asistente que recuerda al cliente; agente que delega en otro	6

Es un prototipo: corre en local o en Colab y no se despliega en internet. El modelo de lenguaje puede ser la API de Gemini en su nivel gratuito o un modelo pequeño abierto, como en los laboratorios.
Tres ejemplos de productos válidos:

- **Asistente de reclamos de una aseguradora:** clasificador de reclamos, asistente que responde sobre las pólizas y agente que abre tickets.
- **Plataforma de cobranza:** *scoring* de mora, asistente que redacta los mensajes con recuperación sobre las políticas de cobranza y memoria del cliente.
- **Mesa de ayuda interna de TI:** clasificador de tickets, asistente que consulta los manuales y agente que ejecuta acciones.

IV. EL REPOSITORIO

Un repositorio **público** de GitHub por grupo. Es público porque GitHub Pages solo publica desde repositorios públicos en las cuentas gratuitas, y porque la página queda abierta en internet de todos modos. Por eso la regla de datos sintéticos no tiene excepciones.

Estructura mínima

```
README.md                qué es, cómo instalarlo y correrlo, enlace a la página
docs/                    la documentación; es también la fuente de la página
  index.md               portada de la página
  ficha.md               entregable 1
  arquitectura.md        entregable 2, con el diagrama en Mermaid
  modelo-de-amenazas.md  entregable 3
  priorizacion.md        entregable 4
  controles.md           entregable 5
  evaluacion.md          entregable 6
  regulatorio.md         entregable 7
src/                     el producto
controles/               los controles que el grupo implementa
datos/                   corpus y datos sintéticos
evaluacion/
  catalogo/              ataques y consultas legítimas (CSV o JSONL)
  correr_evaluacion.py   o un notebook que se abre desde GitHub en Colab
  resultados/            JSON y gráficos de cada corrida, versionados
registros/               muestra del registro de una corrida de ataque
```

```
requirements.txt
.env.example            nombres de las variables, sin valores
```

Arquitectura en Mermaid

El diagrama se escribe en Mermaid dentro de `docs/arquitectura.md`, y GitHub lo dibuja al mostrar el archivo. Cada límite de confianza es un `subgraph`. Un esqueleto de partida:

````
```mermaid
flowchart LR
    U[Usuario] -->|consulta| A
    X[Documento externo] -->|ingesta| C
    subgraph P["Límite de confianza: el producto"]
        A[Asistente] -->|recupera| C[(Corpus)]
        A -->|contexto| M[Modelo de lenguaje]
        A -->|escribe| L[(Registro)]
    end
```
````

Credenciales

La llave de la API va en un archivo `.env` excluido por `.gitignore` y nunca entra al historial. Si una llave llega al historial, el grupo la revoca, la reemplaza y lo documenta como una fila de su modelo de amenazas.

Página de GitHub Pages

Explica el proyecto a quien no va a leer el código: qué es el producto, su arquitectura, las amenazas prioritarias, los resultados de las pruebas, los controles con su riesgo residual y cómo reproducir todo. Se construye desde `docs/`. Se sugiere MkDocs con el tema Material, que dibuja los diagramas Mermaid; sirve cualquier opción en la que el diagrama se vea en la página.

V. ENTREGABLES

#	Entregable	Archivo	Contenido
1	Ficha del sistema	`docs/ficha.md`	Para qué sirve y a quién; sus componentes; qué datos usa y de dónde vienen; quién lo usa y con qué permisos. Una página.
2	Arquitectura	`docs/arquitectura.md`	Diagrama en Mermaid con componentes, flujos de información y límites de confianza, coherente con el código. Un límite de confianza es el punto donde la información pasa entre partes con distinto nivel de confianza; por ejemplo, del usuario al sistema o de un documento externo al modelo.
3	Modelo de amenazas	`docs/modelo-de-amenazas.md`	Una fila por amenaza, con las columnas del curso (tabla siguiente). Cubre las familias de ataque del curso que aplican al producto.
4	Priorización	`docs/priorizacion.md`	Las amenazas ordenadas por explotabilidad (qué tan fácil es llevarlas a cabo) e impacto, con la justificación de las cinco primeras.
5	Controles y riesgo residual	`docs/controles.md` y `controles/`	Para las cinco amenazas prioritarias, qué control proponen, qué detecta y qué deja pasar. Al menos **dos controles implementados** en el código.
6	Evaluación adversarial	`docs/evaluacion.md` y `evaluacion/`	Ver la sección siguiente.
7	Clasificación regulatoria	`docs/regulatorio.md`	El nivel de riesgo del producto bajo la normativa peruana y bajo el reglamento europeo, y dónde divergen. Se ve en la sesión 7.
8	Página y sustentación	GitHub Pages	La página publicada, que sirve de apoyo en la sustentación de la sesión 8.

Las columnas del modelo de amenazas son estas:

Columna	Qué se escribe
Amenaza	Qué puede salir mal.
Activo afectado	Contra qué: el componente, el dato o el documento que la amenaza alcanza.
Propiedad que rompe	La propiedad de seguridad que se pierde; por ejemplo, confidencialidad, integridad o disponibilidad.
Por dónde entra	El punto del producto por donde llega el ataque.
Señal en el registro	Qué rastro queda en el registro del producto y qué no queda, contrastado con una corrida real.
Tipo STRIDE	Su categoría en STRIDE, una clasificación de amenazas en seis tipos: suplantación, manipulación, repudio, divulgación de información, denegación de servicio y elevación de privilegios. Se ve en la sesión 2.
Capa MAESTRO	La capa del sistema donde se ubica según MAESTRO, un marco de modelado de amenazas por capas para sistemas con agentes, publicado por la Cloud Security Alliance. Se ve en la sesión 5.
Control	Qué la reduce. Se ve en la sesión 4.
Prioridad	Su lugar según explotabilidad e impacto.

Las columnas y marcos que todavía no se han visto se completan cuando se enseñan: STRIDE en la sesión 2, el control en la 4, MAESTRO en la 5 y la clasificación regulatoria en la 7.

VI. EVALUACIÓN ADVERSARIAL

Es lo que muestra el efecto real de la seguridad sobre el producto. Usa las técnicas de los laboratorios 2 y 3.

- **Qué se mide.** Al menos tres de las cinco amenazas prioritarias, sobre el producto del grupo.
- **Cuánto.** Un catálogo de al menos 20 intentos por amenaza y al menos 20 consultas legítimas.
- **Cómo.** Cada amenaza se mide sin control y con control. Se reporta la tasa de éxito del ataque con su intervalo de Wilson al 95%, y la tasa de falsos positivos de cada control sobre las consultas legítimas. Un falso positivo es una consulta legítima que el control bloquea.
- **Qué queda en el repositorio.** El catálogo, el código que corre la evaluación con un solo comando o un notebook, los resultados de cada corrida en `evaluacion/resultados/` y una muestra del registro en `registros/`.
- **Qué se escribe en `docs/evaluacion.md`.** Las tasas con sus intervalos, qué cambió con el control, un ejemplo concreto que el control deja pasar y qué se concluye para el riesgo residual.

Los ataques se ejecutan solo contra el producto del grupo. Nunca contra servicios de terceros ni contra sistemas reales.

VII. AVANCE POR SESIÓN

El producto y el modelo crecen con el curso.

Sesión	Qué tiene el repositorio
3	Grupo formado, producto elegido y registro en el formulario con el enlace del repositorio.
4	**Hito 1, con retroalimentación:** ficha, arquitectura en Mermaid, estructura del repositorio y una primera versión de la página publicada. El asistente ya responde sobre sus documentos.
3 a 7	Las filas de cada tema: inyección de prompt (3), controles (4), agentes y capa MAESTRO (5), identidad y memoria (6).
6	**Hito 2, con retroalimentación:** producto con sus tres componentes, registro de eventos, modelo de amenazas en avance y primera medición sin control.
7	Controles implementados y medidos; clasificación regulatoria.
8	**Entrega final y sustentación.**

Entrega final. Es el estado del repositorio en la etiqueta de git `entrega-final`, publicada antes del inicio de la sesión 8. Lo que se suba después no se evalúa.

El trabajo se hace en grupo fuera de clase. Se estima entre dos y tres horas por semana por integrante.

Registro del grupo

En la sesión 3, cada grupo se registra una sola vez en el formulario del docente:
[https://forms.gle/7QpM25QNxAjrUPnu5]

El formulario pide el nombre del grupo, el nombre y el correo de los cuatro integrantes, el producto elegido con sus componentes, el enlace del repositorio y la confirmación de que no incluirá datos reales. Si el producto o el repositorio aún no están listos, registren el grupo con «por definir» y completen el formulario de nuevo antes de la sesión 4.

VIII. SUSTENTACIÓN (SESIÓN 8)

La sesión 8 completa se dedica a las sustentaciones.

Tramo	Qué ocurre
Presentación del grupo (12 min)	Desde la página: el producto, su arquitectura, las cinco amenazas prioritarias, una demostración de un ataque sin control y con control, los resultados medidos y el riesgo residual. La demostración puede ir grabada como respaldo.
Preguntas (10 min)	Cada integrante responde al menos una pregunta, dirigida a él o ella, sobre cualquier parte del producto, del código o de las mediciones: por qué una amenaza tiene esa prioridad, qué señal deja en el registro, qué deja pasar un control, cómo se relaciona con lo que midió en sus laboratorios.

Con cinco o seis grupos, las sustentaciones caben en la sesión con un descanso. El orden se sortea al inicio.

IX. EVALUACIÓN

El trabajo se califica sobre 20 puntos, que pesan el 30% de la nota final. Son cinco criterios de 4 puntos. Cada criterio se califica en uno de cuatro niveles: **Excelente (4)**, **Muy bueno (3)**, **Bueno (2)** y **Por mejorar (1)**. Un criterio sin entrega vale 0.

Equipo, 12 puntos

La misma nota para los cuatro integrantes. Se califica sobre la etiqueta `entrega-final`.

Criterio	Excelente (4)	Muy bueno (3)	Bueno (2)	Por mejorar (1)
1. Producto, arquitectura y documentación	El producto corre siguiendo el README, tiene sus tres componentes y registra consultas, documentos recuperados, acciones y respuestas. El diagrama Mermaid coincide con el código y marca todos los límites de confianza. Los documentos mínimos están completos y la página está publicada.	El producto corre y tiene sus componentes, pero el diagrama o el registro omite un flujo o un límite de confianza, o un documento mínimo está incompleto.	El producto corre solo con ayuda, o le falta un componente o el registro; o el diagrama no corresponde al código en partes importantes; o falta la página.	El producto no corre o no existe, o la documentación no describe lo construido.
2. Modelo de amenazas y detección	Cubre las familias de ataque que aplican, cada amenaza con tipo STRIDE y capa MAESTRO. La señal en el registro está contrastada con el registro real del producto: qué queda y qué no. La priorización por explotabilidad e impacto está justificada en las cinco primeras.	Cubre las familias y justifica la priorización, pero la clasificación por tipo o por capa es parcial, o la señal en el registro no se contrasta con el registro real.	Omite familias que aplican, o la priorización es una lista sin justificar, o documenta señales solo para algunas amenazas.	Incompleto, sin priorización o sin detección.
3. Evaluación adversarial y riesgo residual	Mide al menos tres amenazas prioritarias sin control y con control, con tasas e intervalo de Wilson, y la tasa de falsos positivos de cada control. Las pruebas se repiten con un comando y los resultados están versionados. Muestra un ejemplo concreto que cada control deja pasar.	Mide sin control y con control y reporta intervalos, pero en menos de tres amenazas, o sin falsos positivos, o el riesgo residual es genérico.	Mide una sola condición sin comparar, o reporta tasas sin intervalo, o las pruebas no se pueden repetir.	Sin pruebas medidas o sin controles implementados, o afirma que un control resuelve el problema sin matices.

Individual, 8 puntos

Sale de las preguntas de la sustentación.

Criterio	Excelente (4)	Muy bueno (3)	Bueno (2)	Por mejorar (1)
4. Dominio del trabajo propio	Responde con precisión sobre cualquier parte del producto, del código y de las mediciones, incluida la que no hizo, y la conecta con lo que midió en sus laboratorios.	Responde con precisión sobre su parte y en términos correctos sobre el resto.	Responde correctamente en términos generales, sin anclar en el producto ni en los datos del grupo.	No reconoce el trabajo del grupo o lo contradice.
5. Razonamiento bajo pregunta	Reconoce el límite de una conclusión cuando se le señala, explica de dónde viene y propone cómo verificarla o mejorarla, con otra medición u otro control.	Reconoce el límite y propone una mejora genérica.	Reconoce el límite sin proponer alternativa.	Defiende una posición insostenible o no comprende la pregunta.

Un integrante que no se presenta a la sustentación sin justificación tiene 0 en la parte individual.

X. REGLAS

- **Datos.** Solo datos sintéticos, en el código, en los registros, en la página y en la presentación.
- **Credenciales.** Ninguna llave en el repositorio ni en su historial.
- **Ataques.** Solo contra el producto del grupo.
- **Asistentes de IA.** Permitidos para investigar, programar y redactar. Lo que se sustenta es del grupo: cada integrante responde por todo el repositorio, no solo por su parte.
- **Participación.** El historial de commits muestra quién hizo qué. Sirve de apoyo al docente; la nota individual sale de la sustentación.